

VEILLE RGPD & DONNÉES PERSONNELLES

Conformité, violations, sanctions et nouveaux enjeux (IA, NIS2)

Rapport complet de veille mensuelle BTS SIO SISR — Mai 2026

Note de présentation : Ce rapport exhaustif couvre l'intégralité des données collectées de janvier à mai 2026 auprès de la CNIL (Rapport annuel publié le 19 mai 2026), du CEPD, de l'ANSSI, de l'ICO et des veilles de vulnérabilités spécialisées (ZATAZ). Document de référence pour l'épreuve de veille technologique du BTS SIO SISR.

Sommaire

- 1. Chiffres clés et analyse statistique — Rapport CNIL 2025
- 2. Violations de données : bilan macroscopique et typologies de menaces
- 3. Revue exhaustive des sanctions RGPD majeures (2025-2026)
- 4. Chronologie des incidents récents documentés (ZATAZ, Janvier - Mai 2026)
- 5. L'Intelligence Artificielle au prisme du RGPD : nouveaux chantiers de régulation
- 6. Cadre réglementaire interconnecté : RGPD, AI Act, NIS2, DORA et Code Pénal
- 7. Droits des personnes et obligations légales des organisations
- 8. Recommandations stratégiques et guide opérationnel de mise en conformité
- 9. Glossaire technique et sources de référence

1. Chiffres clés et analyse statistique — Rapport CNIL 2025

Le rapport annuel, rendu public le 19 mai 2026 par Marie-Laure Denis, présidente de la CNIL, dresse un bilan alarmant de l'état de la protection des données personnelles. L'augmentation exponentielle des incidents traduit une industrialisation de la cybercriminalité ciblant tous les pans de la société.

Violations notifiées	Montant total amendes	Plaintes reçues	Sanctions prononcées
6 167	487 M€	20 150	83

« C'est 50% de plus sur ces trois dernières années. Aucune structure n'est épargnée. »

— Marie-Laure Denis, présidente de la CNIL, lors de la présentation officielle le 19 mai 2026

Répartition par typologie d'entités et d'incidents

- 50% - Piratages informatiques** : Constituent l'origine cybercriminelle directe des violations déclarées (Ransomware, phishing ciblé, exfiltration furtive).
- 20% - Administration publique** : En forte hausse comparativement aux 11% mesurés en 2023. Le secteur public a subi un doublement des attaques en 2 ans, touchant les collectivités de toutes tailles.

- **15% - Secteur de la santé** : Les établissements hospitaliers et groupements médicaux restent des cibles privilégiées en raison de la valeur marchande immédiate des dossiers patients.
- **10% - Activités financières et assurances** : Ciblées principalement pour l'extraction de coordonnées bancaires, d'IBAN et de données d'identification permettant l'usurpation d'identité.
- **5% - Erreurs humaines internes** : Divulgations accidentelles (envoi de courriels collectifs sans copie cachée, mauvaise configuration de droits cloud, perte ou vol de supports physiques non chiffrés).

2. Violations de données : bilan macroscopique et typologies de menaces

Selon les indicateurs mondiaux consolidés, la France se positionne au second rang planétaire des nations les plus touchées par les fuites de données massives sur l'année écoulée. Si l'on pondère le volume de données compromises par rapport à la population globale, la France se hisse en tête avec une densité de fuites de données 12 fois supérieure à la moyenne internationale, totalisant plus de 40,3 millions de comptes d'utilisateurs compromis et 5 840 violations majeures officiellement déclarées, soit un bond de 47% par rapport à l'exercice 2024.

Facteurs structurels et techniques de l'explosion des fuites

- **IA et industrialisation de l'attaque [Critique]** : L'Intelligence Artificielle générative permet d'industrialiser les campagnes d'ingénierie sociale (hameçonnage sans fautes d'orthographe, pré-génération de scripts d'attaque personnalisés) et de corréliser instantanément plusieurs fuites historiques pour reconstituer des profils complets.
- **Professionalisation et écosystème cybercriminel [Élevé]** : L'architecture criminelle s'appuie désormais sur les Initial Access Brokers (IAB) qui revendent des accès réseau préalablement compromis à des opérateurs de rançongiciels affiliés, optimisant la rentabilité financière des exfiltrations.
- **Vulnérabilité de la Supply Chain (Sous-traitants) [Surveillance]** : Les attaquants exploitent les interconnexions techniques avec les sous-traitants. La CNIL a durci sa posture opérationnelle en sanctionnant de façon autonome les prestataires de services techniques au même titre que les donneurs d'ordres.
- **Manquements de sécurité persistants [Structurel]** : Les audits de la CNIL révèlent de manière systématique trois failles majeures au sein des SI : l'absence de mécanismes de chiffrement robustes au repos, des politiques de mots de passe obsolètes sans MFA, et une incapacité technique à détecter les exfiltrations de flux réseaux en temps réel (défaut de journalisation).

3. Revue exhaustive des sanctions RGPD majeures (2025-2026)

■ TikTok Information Technologies UK Ltd — 530 M€ (DPC irlandaise)

Catégorie : Novembre 2025 / International

Sanction administrative majeure prononcée par l'autorité irlandaise (DPC) agissant en tant

que guichet unique européen. Le réseau social a été reconnu coupable d'avoir opéré des transferts de données personnelles d'utilisateurs mineurs européens vers des serveurs localisés en République Populaire de Chine, en totale violation du chapitre V du RGPD et sans garanties juridiques ni techniques adéquates. Circonstance aggravante retenue : l'entreprise avait explicitement certifié dans ses déclarations de conformité antérieures qu'aucun flux de données critiques ne transitait vers ce territoire. TikTok a immédiatement interjeté appel devant la Haute Cour irlandaise, entraînant la suspension provisoire de l'exécution financière en l'attente d'un jugement définitif.

■ **FREE et FREE MOBILE — 42 M€ au total (CNIL)**

Catégorie : 13 janvier 2026 / Télécommunications France

La formation restreinte de la CNIL a prononcé deux amendes distinctes : 27 millions d'euros à l'encontre de FREE MOBILE et 15 millions d'euros à l'encontre de la maison-mère FREE. Cette décision fait suite à l'intrusion cybercriminelle massive d'octobre 2024 où un attaquant a exploité une API non sécurisée pour extraire les données personnelles, contractuelles et les Identifiants Nationaux de Compte Bancaire (IBAN) de 24 millions d'abonnés actifs. La CNIL a instruit le dossier sur la base de plus de 2 500 plaintes individuelles de consommateurs. Manquements caractérisés : violation caractérisée de l'article 32 (défaut flagrant de sécurisation), absence de détection d'anomalies de téléchargement de masse sur les serveurs de production, et notification initiale incomplète et tardive des personnes concernées.

■ **France Travail — 5 M€ (CNIL)**

Catégorie : 22 janvier 2026 / Secteur public France

L'opérateur public de l'emploi a fait l'objet d'une sanction pécuniaire de 5 millions d'euros suite à une intrusion survenue au premier trimestre 2024. Des attaquants ont usurpé des comptes de conseillers d'orientation par le biais d'une campagne de harponnage (phishing ciblé). L'enquête technique menée par les commissaires de la CNIL a mis en évidence trois failles de sécurité majeures au regard de l'article 32 du RGPD : absence totale d'authentification multifacteur (MFA) sur les portails d'accès distants des agents, délais d'alerte et de détection comportementale supérieurs à plusieurs semaines, et attribution de droits d'accès trop permissifs permettant à un seul compte d'extraire des requêtes massives sur l'ensemble de la base nationale.

■ **Reddit Inc. — 17 M€ (ICO britannique)**

Catégorie : 24 février 2026 / Réseaux sociaux International

L'autorité de régulation du Royaume-Uni (ICO) a condamné la plateforme communautaire Reddit à une amende de 17 millions d'euros. Les contrôles ont démontré que Reddit collectait, stockait et analysait à des fins de profilage publicitaire les données de navigation d'utilisateurs mineurs de moins de 13 ans résidant sur le territoire national, sans avoir mis en œuvre de base légale valable (recueil du consentement parental requis par l'article 8). Bien que les Conditions Générales d'Utilisation (CGU) interdisaient formellement l'accès aux moins de 13 ans, l'autorité a jugé que l'absence de barrières techniques effectives de vérification d'âge constituait un manquement délibéré à l'obligation de protection des données dès la conception.

■ **Centre Hospitalier Universitaire Norvégien — 112 000 € (Datatilsynet)**

Catégorie : Mars 2026 / Santé Europe

L'autorité norvégienne de protection des données a sanctionné un établissement de santé

public pour avoir stocké des dossiers médicaux hautement confidentiels (données de santé au sens de l'article 9 du RGPD) sur un partage réseau interne accessible par défaut à l'ensemble du personnel administratif et technique, sans restriction logique ni journalisation des consultations. Ce cas fait jurisprudence en Europe sur l'obligation stricte d'appliquer le principe d'accès basé sur le besoin d'en connaître (segmentation des droits applicatifs) et de réaliser des audits réguliers des répertoires Active Directory.

4. Chronologie des incidents récents documentés (ZATAZ, Janvier - Mai 2026)

Le suivi des activités sur les places de marché cybercriminelles (darkweb, salons Telegram cryptés) met en évidence l'exposition immédiate des organisations françaises.

- **15 avril 2026 — Cyberattaque d'envergure contre l'ANTS :** Le portail national France Titres (Agence Nationale des Titres Sécurisés) a été la cible d'une intrusion logicielle majeure. Les bases de données contenant l'état civil, les adresses de contact et les historiques de demandes de documents officiels de 12 millions de citoyens ont été compromises. La Direction Générale de l'Administration et de la Fonction Publique (DGAFP) a immédiatement diligenté une cellule de crise conjointe avec l'ANSSI pour notifier la CNIL sous les 72 heures réglementaires. Un suspect de 15 ans a été interpellé par les services de gendarmerie spécialisés.
- **4 février 2026 — Compromission de la plateforme « Choisir le service public » :** Une attaque ciblée contre l'infrastructure RH de la fonction publique (plateforme CSP gérée par la DGAFP) a permis à des attaquants d'exploiter un identifiant de gestionnaire légitime dépourvu de double authentification. Le vivier complet de candidatures, incluant CV, diplômes, lettres de motivation, numéros de sécurité sociale et coordonnées de 377 418 postulants a été intégralement exfiltré et mis en vente sur un forum cybercriminel russophone.
- **Janvier 2026 — Révélations ZATAZ sur l'historique de France Travail :** En marge de la sanction de 5 M€ prononcée par la CNIL, les analyses forensiques publiées par ZATAZ révèlent que des courtiers en données (data brokers) commercialisaient des accès distants frauduleux aux bases de données de l'organisme sur le darkweb depuis le deuxième trimestre 2022. Cela met en lumière le défaut de surveillance continue et l'absence d'analyse comportementale sur le réseau étatique.
- **Mai 2026 — Vagues de fuites CRM : McDonald's France, Meetic, LDLC :** Des vagues d'exfiltrations successives ont frappé les bases de données d'outils CRM grand public au cours du mois de mai 2026. Pour McDonald's France, les données de fidélité et adresses électroniques ont été siphonnées. Ces incidents rappellent aux administrateurs réseau l'obligation stricte d'encadrer les API tierces et de consigner les requêtes suspectes sous peine de sanctions lourdes.
- **Mai 2026 — Démantèlement d'un réseau de revente de bases de données de masse :** L'Office central de lutte contre la criminalité liée aux technologies de l'information et de la communication (OCLCTIC) a procédé à l'arrestation d'un cybercriminel opérant sous pseudonyme. L'individu administrait un canal Telegram automatisé permettant, via le paiement en crypto-actifs, d'interroger une base agrégée de 79 millions d'enregistrements nominatifs de citoyens français, enfreignant directement les articles 226-16 et suivants du Code pénal.

5. L'Intelligence Artificielle au prisme du RGPD : nouveaux chantiers de régulation

L'année 2026 marque un tournant institutionnel majeur. Par décret gouvernemental, la CNIL a été officiellement désignée comme l'autorité nationale de contrôle et de surveillance unique chargée de faire respecter le nouveau règlement européen sur l'intelligence artificielle (AI Act) sur le territoire français. À ce titre, elle cumule le pouvoir de sanctionner financièrement les usages d'IA interdits et d'auditer de manière approfondie les algorithmes qualifiés de systèmes à « haut risque ».

Directives de conformité pour le déploiement d'outils d'IA

- **Pénétration du RGPD dans l'architecture des LLM** : Les modèles de langage de grande taille (LLM) intègrent, par le biais du 'web scraping' de leur phase d'apprentissage, des volumes massifs de données personnelles. Le Comité Européen de la Protection des Données (CEPD) a émis une doctrine contraignante en 2026 : le droit à l'effacement (article 17) et le droit de rectification (article 16) doivent pouvoir s'exercer directement sur les poids du modèle entraîné ou via des mécanismes d'alignement stricts, sous peine d'interdiction d'exploitation du modèle.
- **Bases d'entraînement et licéité du traitement** : Le développement d'une IA souveraine ou sectorielle exige la justification d'une base légale (article 6 du RGPD). La CNIL préconise d'écarter systématiquement les données sensibles (article 9) lors des phases de filtrage initial et de privilégier des techniques d'anonymisation irréversible ou la génération de données de synthèse.
- **Le fléau de la 'Shadow IA' en entreprise** : L'utilisation non réglementée par les collaborateurs d'outils tiers d'IA générative (ChatGPT, Claude, Midjourney) pour traiter des documents internes de l'entreprise constitue une violation majeure et invisible du RGPD. Les secrets industriels, codes sources propriétaires et données nominatives de clients y sont soumis sans aucun chiffrement ni contrôle de destination, engageant directement la responsabilité juridique de l'employeur.

6. Cadre réglementaire interconnecté : RGPD, AI Act, NIS2, DORA et Code Pénal

■ RGPD (Règlement Général sur la Protection des Données) :

Texte fondateur entré en application en mai 2018, il régit la licéité de la collecte de toute donnée à caractère personnel. Il impose la tenue d'un registre des traitements, la nomination d'un DPO dans les cas requis et la notification des failles sous 72 heures. Plafond des sanctions : jusqu'à 20 M€ ou 4% du chiffre d'affaires mondial annuel.

■ AI Act (Règlement Européen sur l'IA) :

Règlement structuré selon une approche par les risques (Inacceptable, Élevé, Limité, Minimal). Il interdit formellement la notation sociale ou la surveillance biométrique de masse en temps réel. Il impose aux systèmes d'IA à haut risque (RH, infrastructures, éducation) des obligations strictes de transparence, de traçabilité des données d'apprentissage et de supervision humaine constante.

■ Directive NIS2 (Network and Information Security 2) :

Loi de cybersécurité harmonisée applicable en France à plus de 15 000 entités (grandes entreprises, ETI, administrations). Elle impose des obligations de sécurité logique et physique strictes, une gestion des risques de la supply chain numérique et une notification des incidents majeurs sous 24 heures à l'ANSSI. Sanctions financières calquées sur le RGPD (jusqu'à 10 M€ ou 2% du CA mondial).

■ Règlement DORA (Digital Operational Resilience Act) :

Règlement sectoriel d'application stricte dédié aux institutions financières, banques, compagnies d'assurances et à leurs prestataires cloud critiques. Il exige la mise en œuvre de tests de pénétration réguliers conduits par des tiers certifiés (TLPT), une gestion stricte des risques liés aux tiers et des plans de reprise d'activité (PRA) validés. Au premier trimestre 2026, trois fintechs françaises ont vu leur agrément suspendu pour non-conformité majeure.

■ Code Pénal Français (Articles 226-16 et suivants) :

Volet répressif national qualifiant les infractions relatives aux données personnelles. Le fait d'opérer un traitement de données à caractère personnel sans respecter les formalités légales ou de détourner des données de leur finalité initiale est puni de peines allant jusqu'à 5 ans d'emprisonnement et 300 000 euros d'amende d'un point de vue nominatif. En Belgique, la jurisprudence de début 2026 confirme la possibilité d'engager la responsabilité pénale directe du DPO ou du dirigeant en cas de négligence grave, préfigurant une tendance forte en Europe.

7. Droits des personnes et obligations légales des organisations

Les 8 Droits Fondamentaux du RGPD

- **Droit d'accès (Art. 15) :** Permet à tout citoyen d'obtenir de l'organisme la confirmation que ses données sont traitées et d'en exiger une copie exhaustive dans un format compréhensible.
- **Droit de rectification (Art. 16) :** Oblige le responsable de traitement à corriger, actualiser ou compléter les données inexactes ou obsolètes dans les plus brefs délais.
- **Droit à l'effacement / Droit à l'oubli (Art. 17) :** Permet d'exiger la suppression définitive des données lorsque le consentement est retiré, que la finalité est atteinte ou que le traitement est illicite.
- **Droit à la limitation du traitement (Art. 18) :** Offre la possibilité de verrouiller temporairement l'utilisation des données (gel du traitement) pendant que la CNIL ou l'organisme instruit une contestation.
- **Droit à la portabilité des données (Art. 20) :** Donne le droit de récupérer ses données dans un format structuré, couramment utilisé et lisible par machine, afin de les transférer directement à un autre prestataire.
- **Droit d'opposition (Art. 21) :** Permet à la personne de s'opposer à tout moment, pour des motifs légitimes liés à sa situation particulière, à ce que ses données fassent l'objet d'un traitement.
- **Droit d'échapper à la décision automatisée individualisée (Art. 22) :** Interdit qu'une décision produisant des effets juridiques soit prise sur le seul fondement d'un algorithme ou d'un profilage, sans intervention humaine.

- **Droit à l'information transparente (Art. 13 & 14) :** Impose d'informer clairement l'utilisateur, dès la collecte, de l'identité du responsable de traitement, de la finalité précise, de la durée de conservation et des destinataires.

Obligations Institutionnelles des Structures

- **Registre des activités de traitement (Art. 30) :** Document de contrôle obligatoire recensant de manière exhaustive l'ensemble des traitements de données de la structure. Il doit spécifier les catégories de données, les finalités et les mesures de sécurité associées.
- **Analyse d'Impact relative à la Protection des Données (AIPD) :** Obligation légale préalable à la mise en œuvre de tout traitement susceptible d'engendrer un risque élevé pour les droits et libertés (surveillance de masse, exploitation de données de santé, biométrie, profilage par IA).
- **Désignation obligatoire d'un DPO :** Requis pour toutes les autorités publiques, collectivités territoriales, et les entreprises privées dont l'activité principale implique un suivi régulier et systématique à grande échelle de données sensibles.
- **Notification des violations de données (Art. 33 & 34) :** Obligation légale d'informer la CNIL par le biais de son portail en ligne dans un délai maximum de 72 heures après constatation de toute faille de sécurité. Si le risque est qualifié de très élevé pour les personnes, celles-ci doivent être informées individuellement sans délai.

8. Recommandations stratégiques et guide opérationnel de mise en conformité

Sécurisation logique des infrastructures (Volet Technique)

[OK] Déploiement systématique du MFA : L'authentification multifacteur doit être obligatoirement activée sur tous les points d'accès distants (VPN, webmails, consoles cloud, comptes à privilèges).

[OK] Chiffrement généralisé de bout en bout : Appliquer l'algorithme AES-256 pour les données au repos (serveurs de fichiers, bases de données) et les protocoles TLS 1.3 pour les flux réseau en transit.

[OK] Segmentation fine des accès réseau : Implémenter des politiques de filtrage strictes et interdire les répertoires partagés ouverts à tous sans restriction applicative.

Gouvernance et conformité documentaire

[OK] Mise à jour hebdomadaire du registre : Le DPO doit auditer périodiquement les équipes de développement pour consigner les nouveaux flux de données ou l'utilisation d'APIs tierces.

[OK] Généralisation des clauses contractuelles de sous-traitance : Vérifier la conformité RGPD de l'ensemble de la supply chain de l'entreprise par le biais d'audits techniques réguliers.

Gestion de crise cyber et processus d'alerte

[OK] Établissement d'un plan de réponse aux incidents (SLA 72h) : Mener des exercices de simulation de crise pour tester la capacité des équipes techniques (RSSI) et juridiques (DPO) à qualifier une fuite et à notifier la CNIL dans les délais impartis.

[OK] Tenue du registre interne des violations : Consigner exhaustivement tous les incidents de sécurité, y compris ceux n'ayant pas atteint le seuil de notification à la CNIL.

Encadrement des technologies émergentes (IA)

[OK] Interdiction stricte de la Shadow IA : Bloquer au niveau des proxys et pare-feux de l'entreprise les accès aux outils d'IA générative non approuvés par la direction technique.

[OK] Mise en œuvre du principe de Privacy by Design : Intégrer les concepts de minimisation des données et d'anonymisation dès l'idéation de tout projet intégrant des briques d'apprentissage machine.

9. Glossaire technique et sources de référence

- **AIPD** : Analyse d'Impact relative à la Protection des Données. Processus d'évaluation obligatoire des risques d'un traitement.
- **AI Act** : Règlement européen sur l'Intelligence Artificielle, classant les technologies par niveau de risque.
- **CEPD** : Comité Européen de la Protection des Données. Organisme regroupant les autorités de contrôle européennes.
- **CNIL** : Commission Nationale de l'Informatique et des Libertés. Régulateur français des données personnelles.
- **DPO** : Data Protection Officer / Délégué à la Protection des Données. Garant de la conformité au sein de la structure.
- **MFA** : Multi-Factor Authentication. Mécanisme de sécurité exigeant au moins deux facteurs de validation distincts.
- **Shadow IA** : Usage non contrôlé et clandestin d'outils d'IA générative au sein du système d'information de l'entreprise.

Sources documentaires officielles

- CNIL — Rapport annuel d'activité 2025, consulté sur [cnil.fr](https://www.cnil.fr) (publié le 19 mai 2026).
- CNIL — Référentiels et recommandations sur l'usage des systèmes d'IA générative (2025-2026).
- CEPD — Déclarations et lignes directrices sur l'application du RGPD aux modèles LLM (mai 2026).
- ZATAZ — Chroniques de la cybercriminalité et alertes fuites de données (janvier à mai 2026).